

CREATORNIVO

Актуальный статус продукта и дорожная карта

Что уже реализовано, какие исправления подтверждены и что ещё предстоит
добавить

Версия 1.1 | 4 июля 2026

Обновление подготовлено на основе мастер-досье версии 1.0 и последующих исправлений Paddle и авторизации. Документ фиксирует только подтверждённое состояние: развернутые изменения отделены от локальных и ещё не опубликованных.

Внутренний рабочий документ. Не содержит секретных ключей и не заменяет юридическую или бухгалтерскую консультацию.

Содержание

1. Текущий вердикт и статус запуска
2. Зафиксированные решения по продукту
3. Что уже реализовано
4. Изменения после мастер-досье v1.0
5. Генерации, лимиты и usage accounting
6. Paddle: текущая платежная цепочка
7. Auth и временная проблема немедленного входа
8. Что ещё предстоит добавить
9. Инфраструктура и подготовка к Paddle Live
10. Приоритетная дорожная карта
11. Контрольные чек-листы
12. Журнал обновления и технические доказательства

Обозначения статусов

[DONE] реализовано и проверено; [LOCAL] код готов локально, но ещё не опубликован; [IN PROGRESS] причина или решение ещё проверяются; [BLOCKER] блокирует безопасный Live-запуск; [NEXT] следующая рекомендуемая задача; [REVIEW] требует решения владельца или специалиста.

1. Текущий вердикт и статус запуска

Текущий вердикт

Creatornivo имеет рабочую основу для Sandbox Early Access: основные страницы, генерации, серверные лимиты, библиотека, Paddle Sandbox checkout, выдача Pro, Customer Portal и отмена продления работают. Последний сбой, из-за которого subscription.activated с тем же timestamp считался устаревшим, исправлен, опубликован и подтвержден новой тестовой покупкой. При этом обнаружена отдельная временная проблема немедленного повторного входа после регистрации: её точная причина пока не доказана, а диагностический код ещё не развернут.

Область	Статус	Что это означает
Sandbox продукт	Работает	Регистрация, dashboard, templates, generate, library, settings, onboarding.
Paddle Pro	Исправлено и проверено	Новый пользователь получил Pro сразу после платежа.
Refund/chargeback handlers	Есть и покрыты регрессиями	Перед Live всё равно требуется реальный end-to-end refund test и операционный процесс.
Auth diagnosis	LOCAL / IN PROGRESS	Логи и нормализация email готовы локально; ещё не commit/push/deploy.
Paddle Live	BLOCKER	Live account/domain/products/keys/webhook/default link ещё не подтверждены.
Privacy/operations	BLOCKER	Нет завершённых deletion/export, регулярного backup/restore и monitoring.

Главный практический вывод

Сейчас не нужно отключать подписки или переделывать платежную архитектуру. Следующий шаг - опубликовать уже подготовленную auth-диагностику, воспроизвести сбой и получить точную внутреннюю причину вместо общего сообщения Invalid email or password.

2. Зафиксированные решения по продукту

Параметр	Зафиксированное решение
Название	Creatornivo
Домен	https://www.creatornivo.com
Поддержка	support@creatornivo.com
Оператор	Независимый software-проект, управляемый физическим лицом в Украине
Юридический статус	На текущем этапе нет зарегистрированной компании, LLC, Inc. или ФОП
Платежи	Paddle как Merchant of Record; продажи не отключать
Free	5 генераций за UTC-день; до 10 сохранённых prompts; 8 core templates; GPT-4o mini
Pro	100 генераций за UTC-месяц; unlimited saved prompts; все шаблоны; GPT-4o; export .md/.txt; email support
Стандартная цена	\$9.90/month
Early Access	\$4.90/month, ограниченное время без fake counter и fake scarcity
Позиционирование	Не изображать несуществующую компанию, команду или американскую юрисдикцию

Принцип честного позиционирования

Доверие строится на рабочем продукте, прозрачных лимитах, реальной поддержке и честном описании Beta/Early Access. Не использовать fake testimonials, fake ratings, fake counters, недоказуемые обещания скорости, конверсии или экономии времени.

3. Что уже реализовано

Область	Состояние	Комментарий
Главная и Pricing	DONE	Публичный сорп очищен от fake scarcity и недоказуемых claims.
Регистрация / вход	DONE с оговоркой	Credentials auth и bcrypt работают; временный immediate-login incident ещё расследуется.
Dashboard	DONE	Показывает текущий план и серверный usage.
Templates	DONE	15 templates, 8 доступны Free.
Generate	DONE	Серверные квоты, idempotency, streaming; без OpenAI key - безопасный 503 generation_disabled.
Library	DONE частично	Сохранение, поиск, просмотр и экспорт работают; удаления saved items пока нет.
Settings	DONE	Тема, профиль, статус подписки, Customer Portal actions.
Onboarding и mobile header	DONE	Burger, guest/auth меню, responsive, focus, backdrop, System theme.
Paddle Sandbox	DONE	Checkout, receipt, webhook, Pro, portal, update payment method, cancel at period end.
Refund/chargeback logic	DONE технически	Существующие handlers сохраняются и проходят regression suite; Live E2E ещё не выполнен.
Legal pages	REVIEW	Фактически улучшены, но не являются юридическим заключением.
Resources / Guides	NOT ADDED	Архитектура и список тем есть, страницы ещё не созданы.

3.1 Что доказано вручную в Sandbox

- Покупка Pro Monthly за \$4.90 проходит и отображается в Paddle как Complete.
- Webhook переводит нового пользователя на Pro сразу после исправления equal timestamp.
- Settings показывает Current plan: Pro и active subscription до указанной даты.
- Update payment method открывает отдельную Paddle форму.
- Cancel subscription планирует отмену в конце периода; Pro сохраняется до окончания оплаченного периода.

4. Изменения после мастер-досье v1.0

4.1 Исправление одинаковых timestamp у Paddle events

Причина: в subscription-service.ts событие считалось устаревшим при условии `occurredAt <= lastPaddleEventAt`. Поэтому уникальный `subscription.activated` с тем же timestamp, что и `subscription.created`, мог быть отклонён до выдачи Pro.

```
Было: event.occurredAt <= owner.existing.lastPaddleEventAt
Стало: event.occurredAt < owner.existing.lastPaddleEventAt
```

Дополнительно добавлена монотонная обработка равных timestamp: `created` не откатывает существующее состояние/`plan`; `active` не перезаписывается равными `past_due`, `paused` или `canceled`; `trialing` не откатывает `active`; явные `activated/resumed` переходы разрешены; `duplicate event ID` остаётся `duplicate`.

Пункт	Результат
Изменённые файлы	src/lib/paddle/subscription-service.ts; tests/paddle-webhook.test.ts
Коммит	841cef9 - Fix Paddle events with equal timestamps
Проверки	TypeScript PASS; ESLint PASS; webhook/refund 54/54; полный набор 156/156; git diff --check PASS
Deployment	Опубликован; новая Sandbox-покупка подтвердила немедленную выдачу Pro
Не изменялось	База, Prisma schema, миграции, .env, Price IDs

Подтверждено

После deployment новый пользователь зарегистрировался, оплатил Pro Monthly, и план Pro установился сразу. Это закрывает конкретный баг equal timestamp.

4.2 Auth diagnostics и единая обработка email

Отдельная проблема: сразу после регистрации и покупки тот же email/password иногда возвращает Invalid email or password, а через несколько минут вход начинает работать. Точную ретроспективную причину установить нельзя, потому что старый код скрывал любые ошибки Auth.js/Prisma под одним сообщением.

- Регистрация полностью ожидает bcrypt.hash и User.create; отложенной записи passwordHash в коде нет.
- Кэширования отрицательного поиска, read replica и задержки записи пользователя в коде не найдено.
- Paddle обновляет только plan и не перезаписывает passwordHash.
- Наиболее вероятная гипотеза - временная ошибка Prisma/Supabase pooler, но это ещё не доказанный факт.

Изменение	Состояние
Единая email-нормализация	email.trim().toLowerCase() для register/login; пароль остаётся полностью неизменным
Старые аккаунты	Case-insensitive lookup для ранее созданных email с другим регистром
Безопасные причины логов	user_not_found, password_hash_missing, bcrypt_mismatch, database_error, unexpected_authorize_error
Диагностика	request ID, hash email, user ID, DB fingerprint, Prisma code, JWT/session refresh reason
Изменённые файлы	src/app/api/auth/register/route.ts; src/auth.ts; new src/lib/auth/credentials.ts; new tests/auth-credentials.test.ts
Проверки	TypeScript PASS; ESLint PASS; auth 9/9; Paddle 78/78; полный набор 165/165; git diff --check PASS
Текущий статус	LOCAL / STAGED: изменения добавлены через git add, но ещё не commit, push и deploy

Важно

Эта работа пока не является окончательным исправлением задержки входа. Она создаёт диагностическую базу, чтобы следующий production-сбой показал реальную причину: database_error/P2024, user_not_found, bcrypt_mismatch или session/JWT error.

5. Генерации, лимиты и usage accounting

- Клиент создаёт один UUID v4 requestId на одну пользовательскую попытку; network retry использует тот же UUID.
- Синхронный inFlightRef защищает от двух быстрых кликов до React re-render.
- Сервер требует валидный requestId; fallback randomUUID удалён.
- GenerationReservation уникальна по userId + requestId.
- Active duplicate возвращает generation_in_progress; completed duplicate - generation_already_completed; второй OpenAI call не выполняется.
- Reservation создаётся до вызова провайдера; startedAt ставится непосредственно перед OpenAI.
- Ошибка до startedAt не расходует квоту; ошибка/disconnect после startedAt расходует одну генерацию.
- UI не увеличивает usage локально, а пересчитывает /api/ai/usage.
- Без OPENAI_API_KEY Generation/Reservation не создаются и возвращается generation_disabled.

```
Free: 5 generations per UTC day
Pro: 100 generations per UTC month
Counted: status = completed OR startedAt IS NOT NULL
Not counted: reserved without startedAt; failed before startedAt; validation/config/rate-limit rejection
```

Проверка	Текущий вывод
Prisma validate / generate	Успешно на соответствующих этапах
Generation-limit regression	Покрыта отдельными и общими тестами
PostgreSQL Serializable	Нужна отдельная реальная проверка на test/Preview PostgreSQL
Production build	Код компилируется; локальный build может останавливаться только на недоступности Google Fonts

6. Paddle: текущая платежная цепочка

1. Авторизованный пользователь вызывает POST /api/paddle/checkout без client-controlled userId, items или Price ID.
2. Сервер выбирает Early Access или standard Price ID из server configuration.
3. Создаётся PaddleCheckoutIntent, связанный с User; сохраняется transactionId.
4. Клиент открывает Paddle checkout по transactionId и предварительно подставляет session email.
5. Signed webhook связывает transaction/subscription с intent и User.
6. subscription activation переводит User.plan в Pro; равный timestamp больше не блокирует activated.
7. Settings показывает подписку и Customer Portal actions.
8. Cancel subscription отключает будущие продления, но оставляет Pro до конца периода.

Компонент	Статус	Комментарий
Sandbox API key/client token/webhook secret	DONE	Работают в Test Mode
Default payment link	DONE	Настроен
Early Access Price ID	DONE	\$4.90 выбирается сервером
Equal timestamp monotonicity	DONE	Опубликовано и проверено новой покупкой
Refund/chargeback handlers	DONE технически	Regression tests проходят; нужен Live operational test
Live Product/Price/API/webhook	BLOCKER	Отдельное Live-окружение ещё не настроено/подтверждено
Controlled Live purchase/refund	BLOCKER	Не выполнялся

Cancel и refund - разные процессы

Cancel subscription прекращает будущие списания и сохраняет доступ до конца оплаченного периода. Refund текущего платежа оформляется отдельно через Paddle adjustment/support. Даже при готовых handlers перед Live нужно проверить реальный операционный процесс и одну контролируемую покупку с возвратом.

7. Auth и временная проблема немедленного входа

Что наблюдается

Новый пользователь успешно регистрируется и может оплатить подписку. Сразу после выхода попытка войти тем же email/password иногда показывает Invalid email or password. Через несколько минут те же credentials начинают работать без смены пароля.

7.1 Что уже исключено кодовым аудитом

- Register route не отвечает до завершения bcrypt.hash и User.create.
- Отдельной асинхронной дозаписи passwordHash нет.
- Paddle subscription updates не меняют passwordHash, email или auth fields.
- Явного cache, global Map, unstable_cache или read replica для credentials lookup не найдено.
- Ошибка frontend раньше маскировала и неверный пароль, и Prisma/Auth.js ошибки одним текстом.

7.2 Что нужно сделать сейчас

1. Создать commit из четырёх staged auth-файлов.
2. Выполнить git push и дождаться Vercel Ready.
3. Зарегистрировать нового пользователя, сразу выйти и немедленно повторить login.
4. Если сбой повторится, записать точное время и найти [auth-diagnostic] в server logs.
5. Сравнить reason, prismaCode, databaseFingerprint, userFound и passwordHashPresent.
6. Исправлять только подтверждённую причину; не добавлять setTimeout или искусственные retry вместо решения.

```
database_error + P2024 -> проверить Supabase pooler/connection wait/limit
user_not_found -> проверить DB fingerprint и одинаковость environment
bcrypt_mismatch -> искать изменение hash или обработку password
JWT/session error -> исправлять session/cookie/Auth.js flow, а не пароль
```

8. Что ещё предстоит добавить

8.1 Auth, аккаунт и персональные данные

Задача	Приоритет	Результат
Точная причина immediate-login incident	IN PROGRESS	Сначала deployment диагностики и production evidence
Forgot/reset password	HIGH	Одноразовый токен, expiry, безопасный email flow
Change password	HIGH	Для авторизованного пользователя
Login/register/reset rate limiting	HIGH	IP + account identifier; защита от brute force/abuse
Email verification	HIGH для public beta	После готовности почтовой инфраструктуры
Password visibility	MEDIUM	Показ/скрытие на login/register
Input max lengths	MEDIUM	Email/name/password/form limits
Network error UX	MEDIUM	Не путать database/network error с wrong credentials
Account deletion workflow	BLOCKER privacy	Verified support runbook или self-service позже
Personal-data export	BLOCKER/HIGH	Profile, prompts, generations, saved items, timestamps, subscriptions
Delete saved prompts/history	HIGH privacy UX	Удаление пользовательского контента

8.2 Product UX и контент

- Branded error, loading и not-found страницы вместо framework default.
- Явное состояние scheduled cancellation: manage/resume вместо повторной Cancel action.
- Resources / Guides: /resources и /resources/[slug], 3-5 owner-reviewed статей без fake stats.
- Проверка support mailbox: send, receive, reply, spam/deliverability.
- Обновление README и внутренней документации.
- Миграция deprecated middleware convention на проху как отдельная задача.

9. Инфраструктура и подготовка к Paddle Live

Область	Сейчас	Приоритет	Минимум перед Live
Database backups	Есть разовый custom-format pg_dump	BLOCKER	Автоматический schedule, offsite copy, retention, restore drill
Supabase/Prisma pooler	Работает, но возможен transient incident	IN PROGRESS	Подтвердить или исключить по auth diagnostics
Error monitoring	Нет production alerting	HIGH	Webhook/auth/5xx alerts без prompt content
Global OpenAI budget	Есть per-user quota	HIGH	Daily/monthly global breaker и owner alert
Secrets	Vercel env; раскрытый ключ ранее отозван	REVIEW	Rotation runbook, не показывать в screenshots
Support mailbox	Создан	HIGH	Deliverability test
Legal review	Тексты улучшены	REVIEW	Governing law, withdrawal, liability, privacy timing, taxes
Paddle Live	Не подтверждён	BLOCKER	Domain approval, Live product/price/keys/webhook/default link
Live validation	Не проводилась	BLOCKER	Одна покупка + refund малыми деньгами

Production build

Локальный build компилирует код до шага загрузки Geist/Geist Mono и может останавливаться из-за недоступности Google Fonts. Для опубликованной версии фактическим доказательством остаются Vercel Ready и ручной smoke test.

10. Приоритетная дорожная карта

Этап	Задача	Ожидаемый результат	Статус
0	Опубликовать auth diagnostics	Commit, push, Vercel Ready, проверить отсутствие секретов	СЕЙЧАС
1	Воспроизвести login incident	Получить reason/prismaCode/databaseFingerprint и доказать root cause	BLOCKER
2	Исправить подтверждённую auth/DB/session причину	Немедленный register -> logout -> login стабильно работает	BLOCKER
3	Password reset + auth rate limiting	Восстановление доступа и brute-force protection	HIGH
4	Account deletion + personal-data export runbook	Проверяемый DSR workflow и identity verification	BLOCKER
5	Backups + restore drill	Регулярные dumps и подтверждённое восстановление	BLOCKER
6	Monitoring + global OpenAI budget	Alerts и защита от неожиданных расходов	HIGH
7	Legal owner review	Решения по governing law, withdrawal, liability, privacy, taxes	REVIEW
8	Paddle Live onboarding	Domain approval, Live products/prices/keys/webhook/default link	BLOCKER
9	Controlled Live purchase/refund test	End-to-end validation на малой сумме	BLOCKER
10	Resources + branded UX	3-5 статей, branded error/loading/404, polish	ПОСЛЕ BLOCKERS

Рекомендуемый порядок

Не смешивать текущую auth-диагностику с password reset, визуальными правками или Live-конфигурацией. Сначала доказать причину задержки входа и закрыть её минимальным исправлением. После этого переходить к recovery/rate limiting, privacy operations и инфраструктуре.

11. Контрольные чек-листы

11.1 Перед каждым commit/push

- `git status --short` - проверить tracked/untracked изменения.
- `git diff --check` и `git diff --cached --check`.
- Убедиться, что `.env`, ключи, dumps и screenshots с секретами не staged.
- Запустить TypeScript, ESLint изменённых файлов и релевантные tests.
- Просмотреть `git diff --cached --stat` и сам staged diff.
- Создать логичный commit; не использовать `git add` . без осознанной проверки.
- После push дожидаться Vercel Ready и выполнить ручной smoke test.

11.2 Auth reproduction после deployment диагностики

- Новый уникальный email; register.
- Сразу проверить существование dashboard/session.
- Выйти и немедленно выполнить login тем же паролем.
- При ошибке записать точное время и не менять пароль.
- Найти [auth-diagnostic] и сохранить reason, prismaCode, databaseFingerprint, requestId.
- Через 1-5 минут повторить login и сравнить логи.
- Не публиковать пароль, passwordHash, DATABASE_URL или auth secrets.

11.3 Sandbox payment regression

- Guest Pricing показывает \$4.90 и зачёркнутые \$9.90 при Early Access ID.
- Free user CTA открывает Paddle Test Mode checkout.
- Email prefilling соответствует session user.
- Payment Complete; receipt приходит.
- created/activated с одинаковым timestamp не блокируют выдачу Pro.
- Settings показывает active subscription.
- Update payment method и cancellation at period end работают.
- Duplicate webhook event ID возвращает duplicate; разные event ID с равным timestamp обрабатываются по монотонным правилам.

11.4 Перед Paddle Live

- Paddle account/identity verification и website/domain approval завершены.
- Созданы отдельные Live Product, Price IDs, API key, client token и webhook secret.
- Live webhook destination и default payment link настроены.
- Production env не смешивает Sandbox и Live значения.
- Refund/chargeback handlers и операционный процесс проверены.
- Account/privacy workflow, backups, monitoring и support реально исполняемы.
- Выполнена одна контролируемая реальная покупка и refund.

12. Журнал обновления и технические доказательства

Этап	Что изменилось
v1.0 - 4 Jul 2026	Исходное мастер-досье: аудит, Sandbox chain, generation limits, Live blockers и roadmap.
После v1.0	Refund/chargeback handlers уже присутствуют в текущей regression suite; первоначальный blocker переведён в technical done / Live validation pending.
Commit 841cef9	Equal timestamp stale check исправлен с <= на <; добавлена монотонная обработка равных timestamp.
Production verification	Новая Sandbox-покупка: payment Complete, User.plan Pro сразу, Settings active.
Auth diagnostic batch	Email normalization, case-insensitive legacy lookup, safe reason logs, DB fingerprint, JWT/session diagnostics; 165/165 tests.
Текущая точка	Auth batch staged локально, но ещё не commit/push/deploy.

12.1 Ключевые файлы последнего этапа

Область	Файлы
Paddle equal timestamp	src/lib/paddle/subscription-service.ts; tests/paddle-webhook.test.ts
Auth register	src/app/api/auth/register/route.ts
Auth configuration	src/auth.ts
Credentials service	src/lib/auth/credentials.ts (new)
Auth tests	tests/auth-credentials.test.ts (new)

12.2 Последние подтверждённые проверки

Набор	Результат
Equal timestamp batch	Webhook/refund 54/54; full 156/156; TypeScript/ESLint/diff check PASS
Auth diagnostic batch	Auth 9/9; Paddle 78/78; full 165/165; TypeScript/ESLint/diff check PASS
Build	Код проходит компиляцию до external Google Fonts; auth batch ещё не проверен на production deployment

Что не должно попадать в репозиторий или отчёты

.env и реальные API keys/client tokens/webhook secrets; DATABASE_URL и Supabase credentials; auth cookies, session tokens, password hashes/reset tokens; полные Paddle IDs в публичных screenshots; backup dumps в публичном репозитории; prompts/generated content пользователей в logs; личные документы и точный адрес владельца без осознанной необходимости.

Следующее обновление досье рекомендуется сделать после deployment auth diagnostics и получения доказанной причины immediate-login incident. Старую версию следует сохранить как журнал решений, а не перезаписывать.